Modul 24 — JASA-WEB (Web Jasa Pembuatan Project)

Situs jasa pembuatan website dan aplikasi lengkap: etalase tim dan portofolio, form order anti-spam, pelacakan order, serah terima modul penggunaan, dan dashboard admin ber-2FA — Next.js + Supabase

1. Informasi Project

Item	Keterangan
Nama	Web Jasa Pembuatan Project (folder `jasa-web`, paket `jasa-web` v1.0.0)
Jenis	Aplikasi web full-stack (Next.js 15 App Router) dengan Supabase sebagai database, autentikasi, dan penyimpanan
Sasaran	Freelancer atau tim kecil yang menjual jasa pembuatan project (web, mobile, desktop, bot/API)
Perannya	**Admin biasa** (hanya order dan project miliknya) dan **Superadmin** (semua)
Fase	8 fase, seluruhnya sudah digabung dalam satu project (`docs/fase-1.md` s.d. `fase-8-mfa-akses.md`, hanya referensi)
Status	Fase 7 (hardening) dan Fase 8 (2FA, hak per-order) **belum pernah dijalankan/di-build** menurut dokumennya sendiri; jalankan checklist uji sebelum go-live
Nama brand	Masih placeholder `NamaBrand` di `src/lib/site.ts`
Halaman publik	`/` (beranda), `/tim`, `/tim/[slug]`, `/portofolio`, `/portofolio/[slug]`, `/order`, `/lacak`, `/syarat`, `/privasi`
Dashboard	`/admin/login`, `/admin/mfa`, `/admin` (ringkasan), orders, projects, profile, keamanan

2. Tujuan Pembuatan

1. Memberi penyedia jasa **satu etalase profesional** untuk memamerkan tim dan portofolio, sekaligus menerima pesanan secara terstruktur.
2. Mengganti pemesanan lewat chat yang berantakan dengan **form order terstruktur**, kode lacak, dan riwayat status yang transparan bagi klien.

3. Menyerahkan hasil kerja dalam bentuk **modul penggunaan** (informasi, tujuan, manfaat, kelebihan, kekurangan, stack, cara pemasangan, dan fungsi fitur) yang bisa dibuka klien dan dicetak ke PDF.
4. Mengamankan data order dan akses admin dengan standar tinggi: 2FA yang dipaksa **di database**, hak akses per order, dan rate limit atomik.
5. Menjalankan seluruhnya dengan layanan gratis (Supabase, Cloudflare Turnstile, Telegram, Resend) sehingga biaya awal hampir nol.

3. Manfaat

- **Kredibilitas instan:** halaman tim dan portofolio yang bisa diperbarui sendiri dari dashboard, tanpa mengubah kode.
- **Pesanan masuk rapi:** jenis project, stack, anggaran, dan brief tertangkap dalam satu form; notifikasi Telegram dan email langsung ke Anda.
- **Klien tenang:** kode lacak memungkinkan klien melihat status, stepper, dan catatan publik tanpa perlu bertanya terus.
- **Serah terima profesional:** modul penggunaan menjadi nilai tambah yang membedakan jasa Anda dari pesaing.
- **Aman untuk data klien:** order tidak mudah bocor, bahkan bila password admin diketahui orang lain.
- **Kerja tim teratur:** order bisa ditugaskan ke admin tertentu dan dicatat riwayatnya.

> **Mengapa ini menarik?** Klien memilih jasa bukan hanya karena hasil akhirnya, tetapi karena rasa aman sepanjang prosesnya. Situs ini memberi rasa aman itu sejak pesan pertama sampai serah terima.

4. Kelebihan & Kekurangan

Kelebihan

- **2FA dipaksa di database:** `is_admin()` memeriksa `mfa_ok()`; password yang benar pun tidak berguna tanpa kode TOTP, walau penyerang memakai kunci `anon` Supabase untuk menembak API langsung.
- **Kunci login bertingkat:** 2 percobaan gagal mengunci akun 2 → 5 → 15 → 30 menit, dihitung atomik di database sebelum password diperiksa; perilaku sama untuk email yang tidak terdaftar.

- **Hak per-order:** admin biasa hanya melihat order yang ditugaskan kepadanya atau yang belum ditugaskan dan sesuai pilihan klien; semua perubahan lewat fungsi database (tanpa UPDATE/DELETE langsung); log status tidak dapat ditulis langsung.
- **Kode lacak 64-bit:** `ORD-XXXX-XXXX-XXXX-XXXX`; input toleran huruf kecil/spasi/tanpa tanda hubung; pencarian dibatasi 30 kali per 10 menit per IP; halaman lacak tidak pernah menampilkan kontak klien atau catatan internal, dan ditandai `noindex`.
- **Rate limit atomik dan fail-closed** (anti-balapan, menolak bila DB error), IP diambil dari header tepercaya (`TRUSTED_IP_HEADER`), identitas di-hash dengan `RATE_LIMIT_SECRET`.
- **Anti-spam:** Cloudflare Turnstile (di produksi order ditolak bila secret belum diisi).
- **Sampah order 7 hari:** order dipindah ke sampah, bisa dipulihkan, lalu terhapus permanen otomatis (pg_cron); hapus permanen hanya superadmin dan harus mengetik `HAPUS`.
- **Penyimpanan aman:** bucket `portfolio` maks. 2 MB, hanya JPG/PNG/WebP, tidak dapat di-list publik, dan hanya pemilik yang boleh ubah/hapus.
- **Header keamanan:** CSP (Report-Only dulu), HSTS dengan subdomain, COOP, `no-store` untuk `/admin` dan `/lacak`.
- **Validasi ketat:** Zod untuk semua input, URL gambar hanya dari bucket proyek, `mailto:` di-encode, constraint URL di DB.
- **Kemudahan setup:** `npm run check-env` memeriksa kelengkapan environment sebelum `dev` / `build`; `npm run db:setup` menerapkan seluruh skema (dengan opsi data contoh); keepalive GitHub Actions agar proyek Supabase gratis tidak tertidur; Dependabot dan `security:audit`.
- Stiker login yang ramah pengguna (sukses/gagal) sebagai sentuhan personal.

Kekurangan

- **Fase 7 dan 8 belum pernah dijalankan/di-build** (menurut dokumennya sendiri). Wajib menjalankan `npm run typecheck`, `npm run build`, dan checklist uji.
- **Salah rollout 2FA bisa mengunci diri sendiri:** ikuti urutan (aktifkan MFA di Supabase → jalankan migrasi 006 → deploy → daftar perangkat → tambah perangkat cadangan → baru aktifkan `require_mfa`). Sebelum terdaftar, akun belum terlindungi 2FA.
- **Belum ada UI untuk menambah atau menonaktifkan admin;** dilakukan lewat Supabase Authentication + SQL.
- **Gambar yang dihapus dari form tidak langsung terhapus dari Storage;** bersihkan manual sesekali.

- Siapa pun yang memiliki kode order dapat melihat modulnya, jadi **jangan menaruh password atau kunci rahasia** di isi modul.
- Penghapusan otomatis sampah butuh ekstensi **pg_cron** (tanpa itu hanya terjadi saat halaman Sampah dibuka).
- CSP masih mode Report-Only; harus diuji dan diaktifkan sungguhan sebelum go-live.
- Konfigurasi hukum dan brand harus diisi (`legal-config.ts` , `site.ts` , halaman `/syarat` dan `/privasi`), dan data contoh (`contoh-*`) harus dihapus sebelum publikasi.
- Rentang anggaran pada form hanyalah contoh dan perlu disesuaikan dengan harga jasa Anda.
- Next.js 16 akan membutuhkan penggantian nama `middleware.ts` menjadi `proxy.ts` .
- Persyaratan Node.js ketat (`^22.23.4 || ^24.22.1 || >=26.12.1`).

5. Stack Teknologi

Lapisan	Teknologi
Bahasa	TypeScript 5, SQL (PL/pgSQL), JavaScript (skrip `.mjs`)
Frontend & framework	Next.js 15.5 (App Router, middleware), React 19.1, Tailwind CSS 4 (`@tailwindcss/postcss`), Framer Motion 12, lucide-react, React Hook Form 7 + `@hookform/resolvers` , **Zod** 3.25
Backend	Next.js Server Actions dan Route Handlers (`/api/health`), `server-only`
Auth & database	**Supabase** (PostgreSQL, Auth, Storage, RLS) lewat `@supabase/supabase-js` 2.45 dan `@supabase/ssr`
Keamanan	Supabase MFA (TOTP/AAL2), Cloudflare Turnstile, RLS, rate limit di database, CSP/HSTS/COOP
Notifikasi	Telegram Bot API, Resend (email)
Penjadwalan	`pg_cron` (hapus sampah otomatis), GitHub Actions (`keepalive.yml` , `security.yml`)

Lapisan	Teknologi
Skrip dev	`pg` (untuk `db:setup`), `check-env.mjs`, `lib-env.mjs`
Deploy	Vercel (disarankan) atau hosting Node lain

Yang harus disiapkan

Node.js sesuai `engines` (`.nvmrc` tersedia), npm, Git, editor kode, **akun Supabase** (gratis), akun **Cloudflare** (Turnstile), bot **Telegram** (@BotFather), akun **Resend** (opsional), aplikasi autentikator TOTP (Google Authenticator/Authy), serta akun GitHub dan Vercel untuk deploy.

6. Cara Menjalankan (Detail)

6.1 Sekali jalan

```
npm install
cp .env.example .env.local        # Windows: copy .env.example .env.local
```

Isi 4 variabel wajib: `NEXT_PUBLIC_SUPABASE_URL`, `NEXT_PUBLIC_SUPABASE_ANON_KEY`, `SUPABASE_SERVICE_ROLE_KEY` (**tanpa** prefix `NEXT_PUBLIC_`), dan `NEXT_PUBLIC_SITE_URL` (`http://localhost:3000` untuk lokal). Ketiga kunci ada di Supabase → Project Settings → API.

6.2 Menyiapkan database (pilih satu)

- **Manual:** Supabase → SQL Editor → tempel seluruh `supabase/setup.sql` → Run. Data contoh (opsional): jalankan juga `supabase/seed-demo.sql`.
- **Otomatis:** isi `DATABASE_URL` (Supabase → Project Settings → Database → Connection string) lalu `npm run db:setup` (atau `npm run db:setup:demo`). Variabel `DATABASE_URL` hanya untuk setup, **jangan dipasang di hosting**. `DATABASE_CA_FILE` opsional agar koneksi diverifikasi TLS.

6.3 Membuat akun admin

1. Supabase → Authentication → Users → Add user (email + password minimal 12 karakter).

2. **Matikan** "Allow new users to sign up".
3. Edit email di `supabase/link-admin.sql`, jalankan di SQL Editor; kolom `user_id` pada tabel `admins` harus terisi.

6.4 Menjalankan

```
npm run dev
```

- `http://localhost:3000/api/health` harus menjawab `{"ok":true}`.
- `http://localhost:3000` adalah situs publik; `http://localhost:3000/admin/login` adalah dashboard.

6.5 Layanan opsional (wajib sebelum go-live)

Layanan	Variabel	Catatan
Cloudflare Turnstile	`NEXT_PUBLIC_TURNSTILE_SITE_KEY`, `TURNSTILE_SECRET_KEY`	Tambahkan domain `localhost` dan domain produksi; di produksi tanpa secret order ditolak
Rate limit	`RATE_LIMIT_SECRET` (`openssl rand -hex 32`), `TRUSTED_IP_HEADER`	Secret **tidak boleh sama** dengan service role key; di Vercel header tidak perlu diisi
Telegram	`TELEGRAM_BOT_TOKEN`, `TELEGRAM_CHAT_ID`	Buat bot di @BotFather; ambil `chat.id` dari `getUpdates`
Resend	`RESEND_API_KEY`, `NOTIFY_EMAIL_TO`, `NOTIFY_EMAIL_FROM`	`onboarding@resend.dev` hanya untuk uji

6.6 Rollout 2FA (urutan penting agar tidak terkunci)

1. Supabase → Authentication → Multi-Factor Authentication → aktifkan TOTP.
2. Jalankan `supabase/migrations/006_mfa_order_access.sql` (saklar `require_mfa` masih `false`).
3. Deploy kode; setiap admin login lalu diarahkan mendaftarkan 2FA di `/admin/mfa` (pindai QR).
4. Tiap admin membuka **Keamanan** dan menambah **perangkat cadangan**.

5. Setelah semua admin siap, aktifkan `require_mfa`.

6.7 Perintah

Perintah	Fungsi
`npm run dev`	Jalankan lokal (otomatis cek environment)
`npm run build` / `npm start`	Build dan jalankan produksi
`npm run typecheck`	Cek tipe TypeScript
`npm run check-env`	Cek kelengkapan environment
`npm run db:setup`	Terapkan `supabase/setup.sql`
`npm run security:audit`	`npm audit` tingkat high

6.8 Sebelum go-live

Ganti brand di `src/lib/site.ts`; isi `src/lib/legal-config.ts` dan baca ulang `/syarat` dan `/privasi`; hapus data contoh (admin dan project `contoh-*`); isi `NEXT_PUBLIC_SITE_URL` dengan alamat https produksi; tambahkan semua environment variable di hosting (kecuali `DATABASE_URL`); jalankan `npm run typecheck` dan `npm run build`; uji CSP lalu aktifkan sungguhan; aktifkan **pg_cron**; commit `package-lock.json`.

Jika error: "Environment variable wajib belum diisi" → lengkapi `.env.local`; `/api/health` `ok:false` → database belum disiapkan atau key salah; login ditolak → pastikan `user_id` di tabel `admins` terisi.

7. Fungsi Halaman & Cara Mengoperasikan

7.1 Situs Publik (untuk calon klien)

Halaman	Fungsi	Cara pakai
`/` Beranda	Hero, layanan, proses kerja, unggulan portofolio, ajakan memesan	Telusuri lalu klik **Pesan/Order**

Halaman	Fungsi	Cara pakai
`/tim` dan `/tim/[slug]`	Profil anggota tim (foto, bio, tautan) dan project mereka	Pilih anggota untuk melihat detail dan karya
`/portofolio` dan `/portofolio/[slug]`	Daftar project dan detail (thumbnail, screenshot, stack)	Buka satu project untuk melihat stack dan deskripsi
`/order`	Form pemesanan	Isi kontak, **jenis project** (Website, Aplikasi mobile, Aplikasi desktop, Lainnya), stack yang diinginkan, **anggaran**, brief, dan admin pilihan (opsional); selesaikan captcha Turnstile → kirim. Layar sukses menampilkan **kode order** dan tombol **Lacak order sekarang**
`/lacak`	Pelacakan order	Masukkan kode `ORD-XXXX-XXXX-XXXX-XXXX` → lihat status, stepper, dan riwayat (hanya catatan bertanda "terlihat klien")
`/lacak/[kode]/modul`	**Modul serah terima**	Muncul bila admin menerbitkannya; punya daftar isi dan tombol **Cetak / simpan PDF**
`/syarat`, `/privasi`	Syarat Layanan dan Kebijakan Privasi	Isi dari `legal-config.ts`; baca ulang sebelum go-live

7.2 Dashboard Admin

Halaman	Fungsi	Cara pakai
`/admin/login`	Masuk	Email + password (stiker sukses/gagal; terkunci bertingkat setelah 2 kali salah)

Halaman	Fungsi	Cara pakai
`/admin/mfa`	2FA	Belum punya perangkat: pindai QR dan daftarkan; sudah punya: masukkan kode 6 digit
`/admin`	Ringkasan	Jumlah order per status dan order terbaru
`/admin/orders`	Daftar order + filter status	Pilih status untuk menyaring; buka order untuk detail
`/admin/orders/[id]`	Detail order	Lihat brief; tautan **WhatsApp**/email; ubah status (**Baru, Ditinjau, Diterima, Dikerjakan, Revisi, Selesai, Dibatalkan**) dengan catatan **publik** atau **internal**; tentukan developer penanggung jawab; **Pindahkan ke sampah**
`/admin/orders/[id]/modul`	**Editor modul serah terima**	Isi bagian informasi, tujuan, manfaat, kelebihan, kekurangan, stack, cara pemasangan, dan kartu fitur (fungsi + cara penggunaan); blok perintah dibungkus tiga backtick; centang **Publikasikan ke klien** → simpan
`/admin/orders/sampah`	Sampah order (7 hari)	**Pulihkan** atau (superadmin) **Hapus permanen** dengan mengetik `HAPUS`
`/admin/projects` (+ `new`, `[id]`)	Kelola portofolio	**Tambah project**: judul, deskripsi, stack, thumbnail dan screenshot (JPG/PNG/WebP ⩽ 2 MB), centang **Tampilkan di web publik**; admin biasa hanya milik sendiri
`/admin/profile`	Profil publik sendiri	Ubah bio, tautan, foto; langsung muncul di `/tim/<slug>`
`/admin/keamanan`	Keamanan akun	Tambah/hapus perangkat 2FA, termasuk perangkat cadangan

7.3 Siapa Melihat Order Apa

Order	Admin A	Admin B	Superadmin
Ditugaskan ke A	ya	–	ya
Ditugaskan ke B	–	ya	ya
Belum ditugaskan, klien tidak memilih	ya	ya	ya
Belum ditugaskan, klien memilih A	ya	–	ya
Belum ditugaskan, klien memilih B	–	ya	ya
Ditugaskan ke A, klien memilih B	ya	–	ya

7.4 Alur Pelanggan dari Awal sampai Serah Terima

1. Klien mengisi `/order` → mendapat **kode lacak**; Anda menerima notifikasi Telegram/email.
2. Admin meninjau di `/admin/orders`, mengubah status menjadi *Ditinjau* → *Diterima*, dan menulis catatan publik.
3. Klien memantau di `/lacak` selama status berubah menjadi *Dikerjakan*, *Revisi*, lalu *Selesai*.
4. Setelah selesai, admin menulis dan menerbitkan **Modul serah terima**.
5. Klien membuka `/lacak/<kode>/modul` dan menyimpannya sebagai PDF.

8. Kalimat Penutup untuk Calon Pengguna

Proyek terbaik bukan hanya yang selesai tepat waktu, tetapi yang membuat kliennya merasa dilibatkan dari pesan pertama sampai serah terima. **JASA-WEB memberi Anda etalase yang meyakinkan, pesanan yang rapi, pelacakan yang transparan, dan modul penggunaan yang mengesankan — semuanya dijaga keamanan setingkat perusahaan.** Isi satu form order uji, ubah statusnya dari dashboard, dan lihat sendiri bagaimana pengalaman klien Anda berubah menjadi profesional.